LAWYGO PAN

POLICY & OPERATIONS · 2026

사이트 보안규정·보안운영 매뉴얼

LAWYGO PAN 안전한 데이터·콘텐츠 운영 기준



POLICY & OPERATIONS

보안 책임 구분

제품 운영·외부 전문 변호사·광고주 권한을 분리합니다.

- 최소권한 원칙
- 권한 변경은 승인 기록 필요
- 개인정보 열람 권한의 정기 점검

운영 지침 · 검토용

출처·참고: 변호사 광고 규정 · 자료는 사실과 가정을 구분해야 합니다.

POLICY & OPERATIONS

인증·세션

이메일 인증과 변호사 자격증명 검증을 별개로 취급합니다.

- 이메일 인증 토큰 만료 및 일회성 사용
- 보안 쿠키 HttpOnly·Secure·SameSite
- 운영자 계정은 강력한 MFA 필수

운영 지침 · 검토용

출처·참고: 변호사 광고 규정 · 자료는 사실과 가정을 구분해야 합니다.

POLICY & OPERATIONS

API 보안

공개 폼을 통한 취약점과 남용을 방어합니다.

- 입력 길이·형식·허용 도메인 검증
- 속도 제한·서버 측 권한 검사
- CSRF와 CORS·보안 헤더 검토

운영 지침 · 검토용

POLICY & OPERATIONS

외부 콘텐츠

Blogger·YouTube URL을 무조건 서버에서 가져오지 않습니다.

- 화이트리스트 검증
- 서버 SSRF 방어
- 스크립트·HTML 임베드 안전화

운영 지침 · 검토용

POLICY & OPERATIONS

비밀키·배포

SMTP 비밀번호·서명키·DB 주소를 저장소에 커밋하지 않습니다.

- 환경변수 또는 Secret Manager 사용
- 배포별 키 분리
- 유출 감지 시 즉시 회전

운영 지침 · 검토용

POLICY & OPERATIONS

전송·저장 암호화

실제 운영은 HTTPS·TLS, 암호화 저장소를 기본으로 합니다.

- 백업 저장소 접근통제
- 클라이언트 코드에 연락처 원문 포함 금지
- 동의 없이 상담 원문을 AI 모델에 전송 금지

운영 지침 · 검토용

POLICY & OPERATIONS

로그·관측

개인정보를 기록하지 않는 운영 로그가 필요합니다.

- 인증 실패·접근 거부·검수 승인 로깅
- 사고 탐지·이상 트래픽 경보
- 법정 보존 기간과 최소 보관 원칙 병행

운영 지침 · 검토용

출처·참고: 변호사 광고 규정 · 자료는 사실과 가정을 구분해야 합니다.

POLICY & OPERATIONS

광고 사기 방어

유료 노출은 이상 클릭·중복 노출을 감시합니다.

- 상세 분석 데이터 익명화
- 광고 고객 실적 과장 방지
- 검수 승인 이력 변경 불가 로그

운영 지침 · 검토용

출처·참고: 변호사 광고 규정 · 자료는 사실과 가정을 구분해야 합니다.

POLICY & OPERATIONS

백업과 재해복구

유실·랜섬웨어에 대비한 독립 백업과 복구 훈련을 실시합니다.

- 일일 백업과 별도 지역 보관(제안)
- 주기적 복구 테스트
- RTO/RPO는 운영 목표에 따라 설정

운영 지침 · 검토용

POLICY & OPERATIONS

보안 테스트

침투시험·종속성 스캔·웹훅 재전송 테스트를 계획합니다.

- OWASP Top 10 중심 점검
- 외부 라이브러리 취약점 알림
- 배포 전 개인·회원권한 접근 점검

운영 지침 · 검토용

POLICY & OPERATIONS

법적 사고 대응

취약점 발견·침해 신고·정보주체 통지 책임을 문서화합니다.

- 사고 발생 시간과 조치 책임자 기록
- 규제 기관 신고 해당 여부 판단
- 구독자·개인정보 삭제 요청을 추적

운영 지침 · 검토용

출처·참고: 변호사 광고 규정 · 자료는 사실과 가정을 구분해야 합니다.

POLICY & OPERATIONS

운영 전 점검표

프런트엔드 시안과 백엔드 예제를 상용 배포와 혼동하지 않습니다.

- 테스트 SMTP·DB를 운영 인프라로 교체
- 법무 책임자 정책 승인·모의 사고훈련
- 정기 접근권한 검토 후 출시

운영 지침 · 검토용